

Modelo de Encuesta Integral de Métricas e Indicadores de Ciberseguridad

1. Información general de la organización

1.1. Sector principal de actividad de la organización (según CNAE o equivalente interno).

1.2. Tamaño de la organización (personas empleadas):

- Menos de 50
- Entre 50 y 249
- Entre 250 y 999
- 1.000 o más

1.3. Facturación anual aproximada:

- Menos de 10 millones de euros
- Entre 10 y 50 millones
- Entre 50 y 250 millones
- Más de 250 millones

1.4. ¿La organización está identificada o prevé estarlo como "esencial" o "importante" conforme a NIS2 o normativa nacional equivalente?

- Sí, esencial
- Sí, importante
- No
- No lo sabemos todavía

1.5. Rol de la persona que responde a esta encuesta.

2. Gobernanza y programa de medición (enfoque NIST SP 800-55)

2.1. ¿Existe un programa formal de medición de la seguridad de la información a nivel de organización?

- Sí, formalmente definido y aprobado
- En práctica, pero no formalizado
- Parcial (solo algunas áreas)
- No existe

2.2. ¿Se han definido objetivos de negocio explícitos que las métricas de ciberseguridad deban apoyar (p. ej., continuidad de negocio, protección de la vida humana, protección de la cadena de suministro)?

- Sí, documentados y aprobados
- Parcialmente, existen pero no están formalmente documentados
- Solo objetivos técnicos, no de negocio
- No, se miden cosas porque "es lo que hay"

2.3. ¿Existe un documento o inventario que recoja todas las métricas de seguridad utilizadas, con su definición, fórmula, fuente de datos y periodicidad?

- Sí, actualizado y usado regularmente
- Existe, pero está desactualizado
- Está en elaboración
- No existe

2.4. ¿Quién es el responsable último de la aprobación del catálogo de métricas de ciberseguridad?

- Consejo de administración
- Comité de riesgos / auditoría
- Comité de seguridad o similar
- Dirección de Tecnología / CIO / CISO
- No está claro / nadie en particular

2.5. ¿Con qué periodicidad se revisa y ajusta el catálogo de métricas?

- Trimestralmente
- Anualmente
- Cada más de dos años
- Solo cuando ocurre un incidente grave
- Nunca se ha revisado

2.6. ¿Se realiza algún tipo de aseguramiento de la calidad de los datos (validación, reconciliación, controles de integridad) para las métricas de ciberseguridad?

- Sí, sistemáticamente
- Ocasionalmente
- Solo cuando se detecta un error evidente
- No

3. Alcance y tipos de métricas

3.1. De las siguientes categorías, ¿cuáles se miden de forma regular (al menos trimestral)?

- Eficacia de controles de seguridad
- Eficiencia (coste, esfuerzo, tiempos)
- Impacto de incidentes (económico, operativo, reputacional)
- Cumplimiento normativo (ENS, NIS2, RGPD, sectoriales)
- Madurez organizativa (capacidad, procesos, cultura)
- Riesgo residual
- Ninguna de las anteriores de forma sistemática

3.2. ¿Qué predominio tienen actualmente sus métricas de ciberseguridad?

- Mayoritariamente cuantitativas, con valores numéricos claros
- Mezcla equilibrada de cuantitativas y cualitativas
- Mayoritariamente cualitativas (semáforos, escalas subjetivas)
- Básicamente opiniones iluminadas en presentaciones

3.3. En una escala de 1 a 5, ¿hasta qué punto cree que las métricas actuales influyen realmente en las decisiones de presupuesto de ciberseguridad?

- 1: No influyen en absoluto
- 2: Influyen marginalmente
- 3: Influyen de forma moderada
- 4: Influyen de forma significativa
- 5: Son determinantes

3.4. ¿Existe una relación explícita entre las métricas de ciberseguridad y el mapa de riesgos corporativos (ERM)?

- Sí, las métricas alimentan el mapa de riesgos
- Parcialmente, solo algunas métricas
- Se relacionan "de facto", pero no está documentado
- No existe relación clara

4. Indicadores sobre incidentes y amenazas

4.1. ¿Dispone la organización de un proceso formal para registrar y clasificar incidentes de ciberseguridad?

- Sí, formalizado y aplicado en toda la organización
- Formalizado pero aplicado de forma desigual
- Proceso informal, dependiente de personas concretas
- No existe proceso definido

4.2. ¿Qué sistemas se utilizan para registrar incidentes?

- Herramienta ITSM corporativa (p. ej. ServiceNow, JIRA Service Management, etc.)
- SIEM / SOAR
- Hoja de cálculo o similar
- Sistema propio desarrollado internamente
- No se registran de forma sistemática

4.3. ¿Se miden los siguientes indicadores de incidentes? (Seleccione todos los que apliquen)

- Número total de incidentes registrados
- Número de incidentes significativos o críticos
- Tiempo medio de detección (MTTD)
- Tiempo medio de respuesta (MTTR)
- Tiempo medio de recuperación
- Impacto económico estimado de los incidentes
- Impacto en la disponibilidad de servicios críticos
- Ninguno de los anteriores

4.4. ¿Se segmentan las métricas de incidentes por tipo de amenaza (ransomware, phishing, DDoS, insider, etc.)?

- Sí, con clasificación detallada y consistente

- Parcialmente, para algunas tipologías
- De forma ad hoc cuando alguien lo pide
- No, solo se registra "incidente" sin más matices

4.5. ¿Se segmentan las métricas de incidentes por unidades de negocio, países, sedes o sistemas críticos?

- Sí, de forma sistemática
- Parcialmente
- Solo tras incidentes especialmente graves
- No

4.6. ¿Comparte la organización información de incidentes con CSIRTs/CERTs nacionales (p. ej. INCIBE-CERT, CCN-CERT) o sectoriales?

- Sí, de forma habitual
- Sí, pero solo en incidentes graves
- Solo cuando lo exige la normativa
- No

5. Indicadores de controles técnicos y Zero Trust

5.1. ¿Dispone la organización de una arquitectura formalmente definida orientada a Zero Trust (al menos en borrador serio)?

- Sí, con roadmap y hitos definidos
- En diseño, sin aprobación formal
- Aplicamos algunos principios sin llamarlo Zero Trust
- No, seguimos confiando alegremente en el perímetro

5.2. ¿Se miden indicadores sobre autenticación y control de acceso, tales como:

- Porcentaje de cuentas con MFA habilitada
- Porcentaje de accesos privilegiados monitorizados
- Número de cuentas huérfanas o inactivas
- Número de excepciones/grupos "permisos especiales"
- Ninguno de los anteriores

5.3. ¿Se mide la segmentación de la red y el tráfico entre segmentos críticos (por ejemplo, número de flujos permitidos entre zonas, porcentaje de tráfico autorizado vs. bloqueado)?

- Sí, con métricas y umbrales definidos
- Parcialmente
- Solo en auditorías puntuales
- No

5.4. ¿Se miden los niveles de parcheo y gestión de vulnerabilidades, tales como:

- Tiempo medio de remediación por criticidad (CVSS)
- Porcentaje de sistemas con parches críticos aplicados en plazo definido
- Número de vulnerabilidades abiertas por activo crítico

- Porcentaje de falsos positivos en herramientas de escaneo
- Ninguno de los anteriores

5.5. ¿Se mide la eficacia de los controles antimalware, EDR/XDR y similares (por ejemplo, tasa de detección, tasa de bloqueos, cobertura de agentes)?

- Sí, con indicadores regulares
- Parcialmente
- Solo en proyectos o pruebas de concepto
- No

6. Indicadores de cumplimiento normativo (ENS, NIS2, RGPD, sectoriales)

6.1. ¿Dispone la organización de un inventario formal de requisitos normativos aplicables en materia de ciberseguridad (ENS, NIS2, RGPD, sectoriales, contractuales)?

- Sí, inventario completo y mantenido
- Inventario parcial
- Inventario informal (p. ej., en documentos dispersos)
- No

6.2. ¿Se miden niveles de cumplimiento por requisito o control (por ejemplo, porcentaje de cumplimiento por dominio ENS o anexo NIS2)?

- Sí, con métricas cuantitativas
- Solo escalas cualitativas (semáforos, alto/medio/bajo)
- Ocasionalmente en auditorías
- No

6.3. ¿Se definen objetivos de mejora de cumplimiento (porcentaje objetivo, plazos, prioridades) y se hace seguimiento mediante indicadores?

- Sí, de forma sistemática
- Parcialmente
- De forma ad hoc cuando alguien lo pide
- No

6.4. ¿Cuántas auditorías internas o externas de ciberseguridad o ENS/NIS2 realiza la organización al año?

- Ninguna
- 1
- 2-3
- Más de 3

6.5. ¿Se cuantifica el coste (horas, recursos externos, impacto operativo) asociado al cumplimiento de requisitos normativos de ciberseguridad?

- Sí, con cierto detalle
- De forma aproximada

- Solo para proyectos muy grandes
- No

7. Métricas de capacidad organizativa y cultura

7.1. ¿Dispone la organización de un plan formal de formación y concienciación en ciberseguridad?

- Sí, estructurado y anual
- Formación puntual, sin plan global
- Solo formación para perfiles técnicos
- No

7.2. ¿Se miden indicadores sobre formación y concienciación, tales como:

- Porcentaje de empleados que completan la formación obligatoria
- Resultados medios de evaluaciones de conocimiento
- Tasa de clic en simulaciones de phishing
- Número de denuncias internas de posibles incidentes
- Ninguno de los anteriores

7.3. ¿Existe un indicador de "capacidad" o "madurez" de ciberseguridad (por ejemplo, basado en modelos tipo CMMI, NIST CSF, ISO/IEC 27001) evaluado de forma regular?

- Sí, con una escala definida y reevaluación periódica
- Evaluación puntual sin seguimiento recurrente
- Solo evaluaciones cualitativas informales
- No

7.4. ¿Se vinculan las métricas de ciberseguridad a objetivos de desempeño o incentivos (bonus, KPIs) de directivos o responsables de área?

- Sí, de forma explícita
- Parcialmente
- Solo en áreas técnicas
- No

7.5. ¿Cómo calificaría, en una escala de 1 a 5, el "clima cultural" respecto a la ciberseguridad en su organización?

- 1: La ciberseguridad es un estorbo
- 2: Se tolera porque no queda otra
- 3: Se acepta como parte del juego
- 4: Se considera importante
- 5: Es una prioridad estratégica compartida

8. Métricas de impacto, riesgo y resiliencia

8.1. ¿Se cuantifica el impacto económico de los incidentes de ciberseguridad (pérdidas directas, costes de recuperación, sanciones, etc.)?

- Sí, con estimaciones estructuradas

- Solo en incidentes muy graves
- De forma aproximada, sin método estándar
- No

8.2. ¿Se estiman los costes evitados (o pérdidas evitadas) gracias a controles o proyectos de ciberseguridad concretos?

- Sí, regularmente
- Ocasionalmente, para justificar proyectos
- Rara vez
- Nunca

8.3. ¿Se modela el riesgo cibernético en términos actuariales o cuantitativos (por ejemplo, distribuciones de frecuencia y severidad, VaR, escenarios estocásticos)?

- Sí, con apoyo de equipos de riesgo/actuariales
- En fase piloto
- Solo escenarios cualitativos
- No

8.4. ¿Se miden indicadores de resiliencia y continuidad del negocio vinculados a ciberincidentes, tales como:

- Porcentaje de procesos críticos con RTO/RPO cumplidos
- Número de ejercicios de crisis realizados al año
- Porcentaje de lecciones aprendidas implementadas tras simulacros
- Tiempo medio para restablecer operaciones tras ciberataques significativos
- Ninguno de los anteriores

8.5. ¿Se ha definido un indicador global sintético (por ejemplo, un Índice Global de Madurez de Ciberseguridad / IGM) que agregue distintas métricas en una puntuación global de la organización?

- Sí, definido y utilizado
- En diseño o piloto
- Se usan varios índices parciales sin uno global
- No

9. Métricas de inversión, coste y ROI en ciberseguridad

9.1. ¿Se dispone de un presupuesto específico y claramente identificado para ciberseguridad?

- Sí, con desglose por partidas (personas, tecnología, servicios)
- Sí, pero mezclado con otros presupuestos de TI
- Parcialmente identificado
- No

9.2. ¿Qué porcentaje aproximado del presupuesto total de TI se dedica a ciberseguridad?

- Menos del 5 %
- Entre el 5 % y el 10 %

- Entre el 10 % y el 20 %
- Más del 20 %
- No se conoce / no se desglosa así

9.3. ¿Se estiman y registran los costes totales de propiedad (TCO) de los principales proyectos o soluciones de ciberseguridad?

- Sí, de forma sistemática
- Solo en proyectos mayores de un umbral
- Ocasionalmente
- No

9.4. ¿Se calcula algún tipo de retorno de la inversión (ROI) o indicadores análogos (por ejemplo, reducción de pérdidas esperadas, aumento de disponibilidad, reducción de sanciones potenciales)?

- Sí, con un modelo definido
- Sí, pero de forma ad hoc
- Se intentó, pero se abandonó en combate
- No

9.5. ¿Se priorizan las iniciativas de ciberseguridad (proyectos, controles) en función de una combinación explícita de riesgo mitigado y coste?

- Sí, con criterios y modelos claros
- Parcialmente, con criterios semiformales
- Básicamente por urgencia percibida
- Por moda tecnológica o presión comercial

10. Alineamiento con marcos NIST, ENS, NIS2 y otros

10.1. ¿Aplica su organización algún marco de referencia internacional para gestión de ciberseguridad?

- NIST Cybersecurity Framework (CSF)
- NIST SP 800-53 / RMF
- ISO/IEC 27001 / 27002
- Otro (especificar)
- Ninguno de forma explícita

10.2. ¿Se han definido métricas alineadas específicamente con el NIST SP 800-55 (o documentos equivalentes de medición) o se está en proceso de hacerlo?

- Sí, de forma explícita
- En proyecto/piloto
- Se usan métricas "inspiradas" pero sin alineamiento formal
- No

10.3. ¿La organización está sometida al Esquema Nacional de Seguridad (ENS)?

- Sí, como organismo del sector público
- Sí, como proveedor del sector público

- No, pero usamos ENS como referencia
- No aplica / no se considera

10.4. En caso de aplicar ENS, ¿se miden indicadores de cumplimiento y madurez específicos del ENS (por dominios, medidas, niveles)?

- Sí, con métricas cuantitativas y seguimiento regular
- Solo en revisiones puntuales
- De forma cualitativa
- No

10.5. ¿Se ha iniciado algún proceso específico para adaptar métricas e indicadores a los requisitos de NIS2 y su transposición nacional (incluida la interacción con el futuro Centro Nacional de Ciberseguridad)?

- Sí, con plan definido
- En análisis
- Se está a la espera de mayor claridad normativa
- No

11. Perspectiva de futuro

11.1. ¿Qué barreras principales identifica para desarrollar un programa de métricas sólido (tipo NIST) en su organización?

11.2. ¿Qué tipos de métricas considera prioritarias reforzar o incorporar en los próximos dos años?

11.3. Si pudiera pedir un deseo a un hipotético "Comité Internacional de Métricas Sensatas", ¿qué cambiaría en los requisitos normativos actuales sobre indicadores y reporting de ciberseguridad?

11.4. ¿Desea recibir un resumen anonimizado con resultados agregados del sector, para comprobar si su organización está más cerca del Olimpo de la Madurez o de la Edad de Piedra Digital?

- Sí
- No